

category: dotnet-general

tags: [dpapi, protecteddata, security, cross-platform, linux, secret, migration, plaintext]

severity: high

created: 2026-07-26

updated: 2026-07-26

project-origin: RemoteControlTool (IPGS.RemoteControl.CcuClient)

DPAPI `ProtectedData` chỉ chạy Windows — pattern mã hoá secret cross-platform + migrate plaintext cũ không mất dữ liệu

Tình huống gặp phải

App .NET 8 build cross-platform (`win-x64;linux-x64`) lưu SSH password + token vào `profiles.json` plaintext. Yêu cầu: mã hoá bằng DPAPI + tự migrate file cũ. Ràng buộc:

`System.Security.Cryptography.ProtectedData` (package 8.0.0) ném `PlatformNotSupportedException` trên Linux.

Triệu chứng / Lỗi

```
PlatformNotSupportedException: Windows Data Protection API (DPAPI) is not supported on this platform.
```

Bẫy nguy hiểm hơn: nếu chỉ try/catch nuốt lỗi → app **im lặng ghi plaintext trên Linux** — tệ hơn không mã hoá vì tạo cảm giác an toàn giả. Bẫy thứ hai: user cũ có file plaintext — nếu decrypt fail mà throw thì mất cả danh sách profile.

Nguyên nhân gốc rễ (Root Cause)

DPAPI là API Windows thuần (gắn user profile/machine key), .NET không có bản tương đương built-in trên Linux. Không có "DPAPI cho Linux" — đừng tìm.

Giải pháp

Pattern `SecretProtector` (tái dùng được cho mọi app cùng ràng buộc):

```
const string Prefix = "enc:v1:"; // version hoá scheme ngay từ đầu

// Protect: chỉ trên Windows; Linux → cảnh báo NỖI BẬT đúng 1 lần (Interlocked guard),
// lưu plaintext CÓ CHỦ ĐÍCH + log rõ — KHÔNG im lặng.
// Unprotect:
//   - không có prefix → plaintext cũ, trả nguyên vẹn (migrate: sẽ tự mã hoá ở lần Persist kế)
//   - có prefix + Windows → DPAPI decrypt; fail → trả rỗng + log ex.Message (KHÔNG throw, không mất profile)
//   - có prefix + Linux → trả rỗng + log (file copy từ Windows không giải được — nói rõ)
// KHÔNG BAO GIỜ log giá trị secret — chỉ log ex.Message của DPAPI.
```

1. Prefix version (`enc:v1:`) phân biệt plaintext cũ ↔ ciphertext — điều kiện tiên quyết cho migrate mượt.
2. Migrate lazy: đọc plaintext cũ trả nguyên → lần Persist kể tự mã hoá (persist trên bản clone `CloneForStorage`, không mutate object runtime).
3. Mọi failure path trả rỗng + log — không ném exception làm mất cả file dữ liệu.
4. Cảnh báo Linux dùng `Interlocked.CompareExchange` guard để chỉ hiện 1 lần, không spam log.

Áp dụng lại (How to reuse)

- App cross-platform cần mã hoá secret theo user → copy pattern `SecretProtector` (prefix version + migrate lazy + fail-soft).
- Khi thấy `ProtectedData` trong project multi-RID → kiểm tra ngay path Linux có xử lý tường minh không.
- Muốn mã hoá THẬT trên Linux → phải tự chọn scheme (AES + key từ keyring/file permission 600) — quyết định riêng, đừng ghép vào DPAPI.

Chú ý / Cạm bẫy (Gotchas)

- ⚠ TUYỆT ĐỐI không nuốt `PlatformNotSupportedException` rồi ghi plaintext im lặng — phải log/cảnh báo tường minh.
- ⚠ Decrypt fail phải trả rỗng chứ không throw — 1 entry hỏng không được phá cả danh sách.
- ⚠ DPAPI scope `CurrentUser`: file copy sang máy/user khác sẽ không giải được — thông báo lỗi phải nói rõ điều này.
- ⚠ Persist phải atomic (write tmp + `File.Move(overwrite:true)`) — crash giữa chừng khi đang migrate = hỏng file gốc.

Tham chiếu

- Project liên quan: `IPGS.RemoteControl.CcuClient/SecretProtector.cs`, `ComputerProfileStore.cs` (fix S7, commit 0146cb4)
- GOTCHAS repo RemoteControlTool: G016